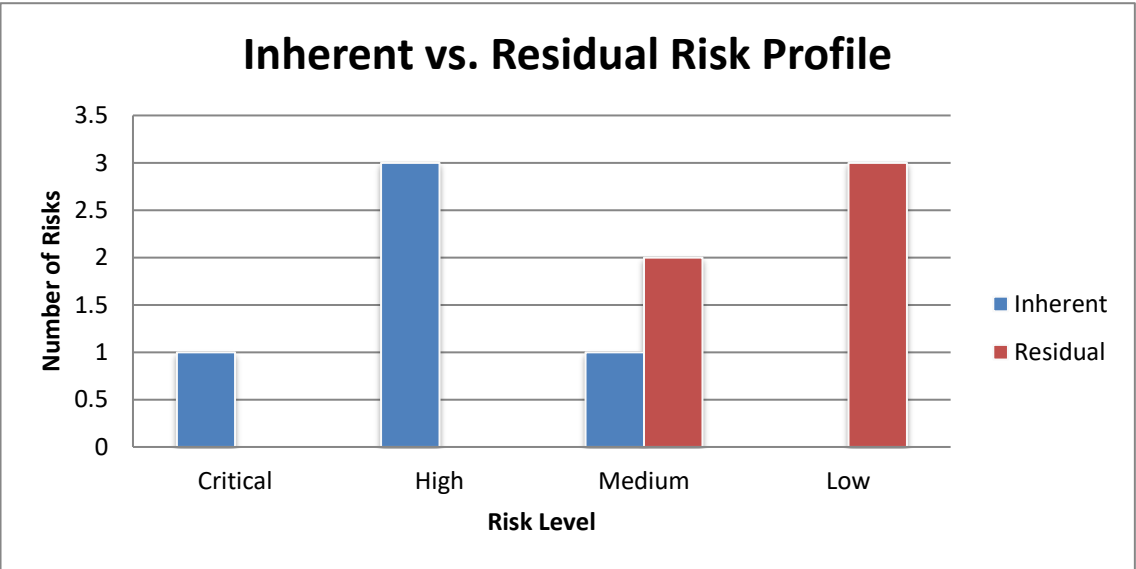


Apex IT Services - GRC Risk Summary

Risk Level	Inherent	Residual
Critical	1	0
High	3	0
Medium	1	2
Low	0	3



Risk ID	Category	Threat / Vulnerability	Inherent Risk	Existing Controls	Treatment Strategy	Residual Risk	Owner	Status
R-01	Cybersecurity	Client Phishing Compromise: A client's employee falls for credential harvesting, leading to unauthorized network access.	High	Spam filtering; basic email security protocols.	Mitigate: Deploy mandatory, automated Managed Security Awareness Training (MSAT) for all client endpoints.	Low	CISO	Open
R-02	Application Security	Database SQL Injection: Malicious actors exploit poorly sanitized inputs on a hosted web app to access backend databases.	High	Web Application Firewall (WAF).	Mitigate: Implement strict parameterized queries; conduct routine vulnerability scans using automated penetration testing tools.	Medium	DevSecOps	In Progress
R-03	Third-Party Risk	Vendor Supply Chain Breach: A third-party software vendor is compromised, introducing malware into Apex IT's management tools.	Critical	Standard vendor selection process.	Transfer & Mitigate: Require SOC 2 Type II reports from critical vendors; maintain comprehensive cyber liability insurance.	Medium	Vendor Mgmt	Open
R-04	IT Operations	Unpatched System Exploitation: Vulnerabilities in Windows or Linux environments are exploited before patches are applied.	High	Manual monthly patch cycles.	Mitigate: Automate patch management workflows; deploy an AI-driven intrusion detection system (IDS) to flag anomalous traffic in real-time.	Low	IT Ops	In Progress
R-05	Compliance & Privacy	Compliance Violation (Data Privacy): Failure to properly secure personally identifiable information (PII) leads to regulatory fines.	Medium	Privacy policy in place; basic encryption.	Mitigate: Map current data flows to standard GRC frameworks (like NIST CSF); enforce data-at-rest encryption across all storage arrays.	Low	Compliance Officer	Closed